

PRIMARY DIRECTIVE: ZERO DOWNTIME & APPLICATION PRESERVATION

The existing application is verified fully operational. Live Docker containers on port 7080 will remain active and untouched. No production database migrations, automated deployments, container resets, or live ERPNext write operations will be performed.

1. Discovered Architecture & Baseline Status

FRONTEND STACK & CONTAINER

React 18.3.1 • TypeScript 5.7.2 • Vite 5.4.21

Multi-stage Dockerfile (Node 20 Alpine builder → Nginx Alpine server). Ports 7080, 3000, 80.

BACKEND & ERPNEXT INTEGRATION

Frappe REST Client + In-Memory Fallback

Target ERPNext Desk: http://45.195.159.86:8280.
Production ERPNext access is employee/intern scoped.

GIT & WORKSPACE ENVIRONMENT

Standalone Local Workspace Needs Isolated Repo

Currently inside user root Git. Must initialize clean dedicated git in project root with branch ci/hrms-access-controls.

BASELINE QUALITY GATES

TypeScript: 0 Errors • Build: 4.08s Clean

Bundle size ~1.3MB gzipped to ~315KB. All components compile cleanly without syntax regressions.

2. Access Control Principles & Boundary Enforcement

- Principle of Least Privilege:** Employees, interns, and contract personnel can only access their own dossier, shift ledger, leave applications, and assigned assets. Cross-user ID manipulation (IDOR) is strictly rejected at the service and query layer.
- Designated Approver Isolation:** Niky Sharma (ETHX-005) is the authorized Main HR operator for company attendance and leave approvals. Madhavi Singh (ETHX-006) is IT HR and does not inherit administrative approval rights.
- Self-Approval Prohibition & Escalation:** Niky Sharma cannot approve her own leave applications. Her requests automatically route to Company Director Ram Chaturvedi (ETHX-001) for executive sign-off.
- Intern Policy Bounds:** 8 Unpaid Interns (ETHX-014 to ETHX-021) operate under a strict 1 July 2026 – 30 September 2026 schedule with an unpaid-leave-only policy. The end date will not trigger automated account deletion, fabricated salary deductions, or unauthorized status alterations.

ETHX HRMS Personnel & RBAC Matrix

Complete 21-Personnel Identity & Authorization Specification

Section 3 • RBAC Policy

3. Verified 21-Personnel Directory & Role Mappings

Emp ID	Full Name	Designation	Role & Category	Access Boundaries & Scope
ETHX-001	Ram Chaturvedi	Company Director	DIRECTOR	Executive Board oversight, escalations, Niky Sharma leave approver.
ETHX-002	Rohan	Company Director	DIRECTOR	Executive Board member; corporate governance records.
ETHX-003	Virender Kumar	Company Director	DIRECTOR	US Contract business oversight; executive records only.
ETHX-004	Siva Kumar	IT Director / Manager	IT LEADERSHIP	Engineering supervisor; no global attendance/leave admin rights.
ETHX-005	Niky Sharma	Main HR	HR ADMIN	Company-wide attendance & leave approvals. Self-approval blocked.
ETHX-006	Madhavi Singh	IT HR	HR EXECUTIVE	IT recruitment & onboarding; no automatic leave approval grant.
ETHX-007	Shubham Patane	Employee	EMPLOYEE	Personal shift ledger, 18/12/10 leave quota, personal IT asset.
ETHX-008	Saurav Sarkar	Employee	EMPLOYEE	Personal shift ledger, 18/12/10 leave quota, personal IT asset.
ETHX-009	Vishal Walunj	Employee	EMPLOYEE	Personal shift ledger, 18/12/10 leave quota, personal IT asset.
ETHX-010	Shruti Pawar	Employee	EMPLOYEE	Personal shift ledger, 18/12/10 leave quota, personal IT asset.
ETHX-011	Ganesh Kulkarni	Employee	EMPLOYEE	Personal shift ledger, 18/12/10 leave quota, personal IT asset.
ETHX-012	Archit Sharma	Contract Employee	CONTRACT	Remote contract operations; personal shift ledger & contract terms.
ETHX-013	Rajnesh	Contract Employee	CONTRACT	Contract operations; personal shift ledger & contract terms.
ETHX-014	Deepti Tiwari	Unpaid Intern	INTERN	Personal 3-month attendance (Mon-Wed WFO, Thu-Fri WFH), unpaid leave.
ETHX-015	Goraksh Kaduskar	Unpaid Intern	INTERN	Personal 3-month attendance (Mon-Wed WFO, Thu-Fri WFH), unpaid leave.
ETHX-016	Rushikesh Kulkarni	Unpaid Intern	INTERN	Personal 3-month attendance (Mon-Wed WFO, Thu-Fri WFH),

Emp ID	Full Name	Designation	Role & Category	Access Boundaries & Scope
				unpaid leave.
ETHX-017	Utkarsh	Unpaid Intern	INTERN	Personal 3-month attendance (Mon-Wed WFO, Thu-Fri WFH), unpaid leave.
ETHX-018	Shakti Thakur	Unpaid Intern	INTERN	Personal 3-month attendance (Mon-Wed WFO, Thu-Fri WFH), unpaid leave.
ETHX-019	Sayali Mahant	Unpaid Intern	INTERN	Personal 3-month attendance (Mon-Wed WFO, Thu-Fri WFH), unpaid leave.
ETHX-020	Preeti Bagal	Unpaid Intern	INTERN	Personal 3-month attendance (Mon-Wed WFO, Thu-Fri WFH), unpaid leave.
ETHX-021	Krishna Tiwari	Unpaid Intern	INTERN	Strict self-service: Own profile, Asus Vivobook, syllabus, own attendance.

GitHub Actions CI Pipeline Architecture

4. Continuous Integration Pipeline Specification

PIPELINE TRIGGERS & SECURITY BASELINE

- Triggers:** push to main / master, pull_request to default branch, and manual workflow_dispatch.
- Permissions:** contents: read (Least privilege principle; tokens cannot write to repository).
- Concurrency:** Grouped by ref with cancel-in-progress: true to avoid redundant resource consumption.
- Timeout:** 15 minutes strict threshold to eliminate hung jobs.

Multi-Stage Job Topology

Stage	Commands Executed	Security & Quality Objectives
1. Lint & TypeCheck	npm ci npx tsc --noEmit	Ensures strict TypeScript compilation, import integrity, and zero type regressions before any code is built.
2. Automated RBAC Tests	npx tsx src/tests/attendance_leave.test.ts	Executes synthetic test suite validating access denial for unauthenticated users, IDOR defense, and self-approval blocks.
3. Production Web Build	npm run build	Verifies bundle chunking, asset minification, and CSS compilation with Vite in a clean CI container.
4. Docker Container Build	docker build -t ethx-hrms:ci .	Guarantees that the multi-stage Nginx container builds successfully without deploying or replacing live containers.

5. Step-by-Step Implementation Roadmap

- Phase 1: Local Checkpoint & Isolated Git Repository**

Create a dedicated .gitignore inside the project root to securely omit .env, node_modules, and build caches. Initialize a dedicated git repo within the folder and branch to ci/hrms-access-controls.
- Phase 2: RBAC Test Automation & Service Logic Fix**

Configure npm test script. Enhance src/services/hrmsService.ts so headless test runners and API callers validate callerUserId accurately. Ensure all 32+ RBAC tests pass with 100% green output.
- Phase 3: GitHub Actions CI Workflow Setup**

Commit .github/workflows/ci.yml configured with caching, timeout, and the 4-stage validation pipeline.
- Phase 4: Remote Sync & Reviewable Pull Request**

Connect to GitHub user darkeren27, create/configure remote ethx-hrms, push branch ci/hrms-access-controls, and generate an unmerged Pull Request.
- Phase 5: Documentation & Audit Delivery**

Deliver CI_SETUP.md with full local verification commands, workflow descriptions, and recovery rollback steps.